

Cyber Tabletop Exercise

Energy OT Intrusion Affecting Generation

NorthGrid Electric Utility · Generation Plant OT Network
Based on STIX bundle `bundle--22d63d20-95f1-4188-a9a7-2a81a2d75538`

Audience: Executive crisis cell, operational leadership, OT engineering, SOC/IR, legal, communications, and regulatory liaison.

Exercise duration: 90 minutes recommended. Timeline is local plant operating time. All scenario content is fictional and intended to test decision-making, escalation, containment, and safe restoration.

1. Agenda

- Welcome, objectives, exercise structure, and rules of engagement.
- Scenario briefing: NorthGrid generation plant OT environment and threat context.
- Four phased injects with facilitated discussion and expected actions.
- Decision points: remote access containment, OT configuration validation, operational continuity, regulatory notification, and restoration.
- Final debrief, lessons learned, action owners, and MITRE ATT&CK mapping.

2. Exercise Objectives

- Test the organization's ability to identify and triage suspicious remote access into an OT environment.
- Validate escalation paths between SOC, OT operations, engineering, crisis management, legal, communications, and executive leadership.
- Exercise safe containment decisions that balance cyber risk with generation stability and worker/public safety.
- Assess the process for validating OT configuration baselines before returning systems to normal operation.
- Prepare concise internal, external, and regulatory communications for an incident affecting generation stability.

3. Scope and Assumptions

- Organization in scope: NorthGrid Electric Utility (energy sector).
- Technical environment in scope: Generation Plant OT Network — Operational technology network supporting plant control, monitoring, and generation operations.
- Threat actor in scenario: Grid Access Operator (nation-state). Attribution is not confirmed during the exercise and should not drive operational response.
- Safety systems remain available, but plant output becomes unstable after unauthorized set-point changes.
- The exercise is discussion-based; no live systems are touched.

4. Rules of Engagement

- Real incidents and safety issues take priority.
- There are no right or wrong answers; the goal is to surface gaps and strengthen preparedness.
- Answer from your real role, authority, and operating procedures.
- Do not fight the scenario; ask for reasonable clarifications through the facilitator.
- Capture decisions, assumptions, unresolved issues, and action items.

5. Scenario Overview

Suspicious remote access and unauthorized OT configuration changes affect generation stability.

NorthGrid’s SOC observes suspicious remote access associated with an engineer account. The activity begins as an identity and access investigation, then escalates when logs show OT access through a jump host and unauthorized set-point changes affecting generation stability. The organization must contain the suspected compromise, preserve evidence, maintain safe operations, validate the OT configuration baseline, and prepare a regulator-facing incident notification.

Primary exercise tensions

- Rapid containment vs. maintaining safe and reliable generation operations.
- SOC-led cyber investigation vs. OT engineering authority over plant configuration and safe restoration.
- Early uncertainty vs. timely executive, operational, and regulatory communications.
- Credential revocation and network isolation vs. the need for remote engineering support.

Key roles to include

Role	Expected focus during exercise
Executive / Crisis Lead	Set priorities, approve major business decisions, ensure cross-functional coordination.
SOC / Incident Response	Triage alerts, preserve evidence, disable compromised access, recommend containment.
OT Operations	Maintain plant safety and generation stability; determine operational workarounds.
OT Engineering	Review configuration changes, compare against baselines, approve safe rollback/restoration.
Legal / Regulatory	Determine notification obligations and review regulator-facing statements.
Communications	Prepare internal messages and external holding statements.
Business Continuity	Coordinate generation impacts, customer implications, and restoration dependencies.

Inject 1: Inject 1 - Suspicious VPN Login

Exercise time: T+0 / 18:40

Primary audience: SOC, OT Operations, OT Engineering

Inject content: SOC detects a successful VPN login using an engineer account from an unusual foreign IP address outside normal working hours.

Discussion questions

- What immediate triage steps are required to validate the VPN login and determine whether this is suspicious or authorized emergency work?
- Who owns the decision to suspend the engineer account, revoke sessions, and restrict remote access?
- What evidence must be preserved before containment actions are taken?
- What escalation threshold brings OT leadership and the crisis cell into the response?

Expected actions / facilitator cues

- Confirm account owner, location, MFA status, VPN source, session history, and change windows.
- Open or upgrade cyber incident record; preserve VPN, identity provider, endpoint, jump host, and OT access logs.
- Notify SOC lead, OT duty manager, and engineering manager; define initial severity and escalation trigger.

Facilitator note

Do not let the discussion jump immediately to attribution. Keep participants focused on identity validation, evidence preservation, and escalation.

Inject 2: Inject 2 - OT Access Confirmed

Exercise time: T+1 hour / 19:40

Primary audience: SOC, OT Engineering, Crisis Lead

Inject content: Engineering workstation logs show the same account accessed the generation plant OT network through the remote access jump host.

Discussion questions

- What additional containment should be applied to the jump host and engineering workstation without disrupting safe plant operations?
- How will SOC and OT engineering jointly determine whether the account performed authorized or unauthorized actions?
- What communications should be sent to plant leadership and executive stakeholders at this stage?
- What assumptions should be documented for later regulatory and post-incident reporting?

Expected actions / facilitator cues

- Disable affected credentials, revoke active sessions, block suspicious IPs, and restrict OT remote access.
- Forensically preserve affected jump host and workstation logs; verify if other accounts or hosts show similar activity.
- Establish joint SOC/OT incident bridge and document containment decisions against safety constraints.

Facilitator note

Probe whether the crisis cell advises or decides. SOC should lead technical containment recommendations, while OT owns safe operational execution.

Inject 3: Inject 3 - Control Logic Change

Exercise time: T+3 hours / 21:40

Primary audience: OT Operations, OT Engineering, Executive Crisis Cell

Inject content: Operators observe unauthorized set-point changes on plant control systems. Generation output becomes unstable and manual engineering review is required.

Discussion questions

- What operational actions are needed to stabilize generation output and protect personnel, equipment, and the grid?
- Who has authority to roll back set-point or control logic changes, and what independent verification is required?
- Do remote engineering connections remain disabled, restricted, or temporarily restored under emergency controls?
- What external dependencies must be notified, including grid operator, vendor support, and regulator liaison?

Expected actions / facilitator cues

- Shift to approved manual/validated operating procedures where necessary.
- Compare controller, engineering workstation, and HMI configurations against trusted baselines.
- Perform engineering review before rollback; confirm generation stability and safety interlocks.

Facilitator note

Challenge participants to separate cyber eradication from process safety restoration. A system can be technically contained but operationally unsafe to reconnect.

Inject 4: Inject 4 - Regulatory Notification

Exercise time: Next business morning / 09:00

Primary audience: Executive, Legal, Regulatory, Communications

Inject content: The national energy regulator requests an incident notification covering operational impact, containment measures, and expected restoration timeline.

Discussion questions

- What information can be provided confidently to the regulator now, and what remains under investigation?
- What containment, eradication, and validation evidence supports safe restoration?
- Who approves the restoration timeline and public/regulatory messaging?
- What after-action items should be assigned before exercise closeout?

Expected actions / facilitator cues

- Prepare regulator notification with impact, containment, restoration estimate, known unknowns, and next updates.
- Maintain executive-approved message discipline; avoid premature attribution.
- Define post-incident monitoring, credential reset scope, remote access hardening, and lessons-learned actions.

Facilitator note

Ask for a concise notification draft: impact, timeline, containment, restoration, and next update commitment.

6. Decision Log Template

Time	Decision	Owner	Rationale / assumptions	Follow-up

7. Communications and Regulatory Preparation

- Internal holding statement: suspicious remote access is under investigation; affected credentials are contained; plant operations are being monitored.
- Executive update: current operational impact, safety posture, containment status, decisions needed, and expected next update.
- Regulator notification: incident timeline, generation impact, containment measures, safe restoration approach, customer/grid impacts, and open investigative items.
- External/public statement, if needed: focus on operational reliability and safety; avoid unconfirmed technical details and attribution.

8. Recovery and Restoration Criteria

- Compromised credentials disabled and reissued only after identity verification and MFA review.
- All active remote sessions terminated; jump host and engineering workstation reviewed for persistence or unauthorized tooling.
- Controller configuration, control logic, set points, and engineering workstation project files validated against trusted baselines.
- OT engineering confirms safe operating state; SOC confirms no active adversary access; executive/operations approve return to normal operations.
- Enhanced monitoring remains in place for remote access, engineering workstation activity, controller changes, and anomalous process conditions.

9. MITRE ATT&CK; Mapping

Scenario element	Framework	Technique / ID	Tactics reflected	How it appears in the exercise
Valid Accounts for Remote Access	Enterprise ATT&CK	T1078	Initial Access, Persistence, Privilege Escalation, Defense Evasion	Successful VPN login using an engineer account from an unusual foreign IP outside normal hours.
Modify Control Logic	ATT&CK for ICS	T0886	Initial Access / Lateral Movement in ICS; impact path through unauthorized remote access	Remote access through the jump host enables unauthorized OT activity. The set-point/control logic change should also be mapped to ICS Modify Parameter / Modify Program if formally catalogued.
Unauthorized set-point changes	ATT&CK for ICS	T0836 Modify Parameter	Impact / Impair Process Control	Operators observe changed set points and unstable generation output.
Unauthorized control logic change	ATT&CK for ICS	T0889 Modify Program	Impact / Impair Process Control	Engineering review is required to compare controller logic against the trusted baseline.
Use of remote jump host	ATT&CK for ICS	T0886 Remote Services	Initial Access / Lateral Movement	The same account reaches the generation plant OT network through remote access infrastructure.

Note: The uploaded STIX object labels the OT behavior as “Modify Control Logic” with external ID T0886. Current MITRE ATT&CK; for ICS identifies T0886 as Remote Services; this exercise preserves the STIX mapping and also adds explicit ICS mappings for parameter/program modification to avoid ambiguity.

10. Courses of Action from STIX

Disable Compromised Remote Access: Disable affected credentials, revoke sessions, and restrict remote access into OT environments.

Validate OT Configuration Baseline: Compare controller and engineering workstation configurations against trusted baselines before returning to normal operation.

11. Glossary

Term	Meaning
OT	Operational Technology supporting physical process control and monitoring.
SOC	Security Operations Center responsible for cyber monitoring and incident response.
Jump host	Controlled intermediary system used to access restricted environments.
Set point	A configured target value used by a control system to operate equipment or process conditions.
Configuration baseline	Trusted reference state for systems, controller logic, project files, and operational settings.
MFA	Multi-factor authentication.

12. Debrief and Lessons Learned

Use the questions below to close the exercise and capture improvement opportunities.

- Where did the team have clear authority, and where did decision ownership become ambiguous?
- Were SOC and OT engineering responsibilities well separated and coordinated?
- Were safety, generation stability, evidence preservation, and containment balanced appropriately?
- Could the organization produce a regulator-ready update within the expected timeframe?
- Which playbooks, contact lists, baselines, monitoring rules, or remote access controls should be improved?

Confidence rating

Capability	1	2	3	4	5	Notes
Suspicious remote access triage						
SOC/OT escalation and coordination						
Safe OT containment and restoration						
Regulatory notification readiness						
Configuration baseline validation						

Sources

Primary scenario source: uploaded STIX bundle 02_energy.json. ATT&CK; technique validation uses MITRE ATT&CK; Enterprise and ICS references for Valid Accounts, Remote Services, Modify Parameter, and Modify Program.